D2 - Secure Symmetric Encryption Module

Team 1:
Gonzalez Fernandez Jonathan Uriel – 420051871 / jonathanuri123@gmail.com
Gabriel Hernández Yukioayax Canek – 321058526 / yukio.gabriel.h@gmail.com
Paz Rosas Jesús Eduardo – 315134854 / jesuspazrosas@gmail.com
Vázquez Apolonio Armando – 315140725 / armandovaz090@gmail.com

October 17, 2026

Selected AEAD algorithm

AES-256-GCM (Advanced Encryption Standard in Galois/Counter Mode) was implemented because it is an industry-standard, hardware-backed algorithm operating under the AEAD (Authenticated Encryption with Associated Data) paradigm. It was selected because it hermetically seals both confidentiality and authenticity in a single mathematical operation, ensuring that nobody can read the message or alter a single bit without the system detecting it immediately.

Key size

It was decided to use symmetric keys of **256 bits** (32 bytes) generated via the operating system's CSPRNG **(os.urandom)** to provide the maximum level of symmetric security available against brute-force attacks and predictable quantum computing. This length ensures that the key space remains computationally invulnerable using current technological resources.

Nonce strategy

A unique nonce of **96 bits (12 bytes)** generated randomly on each execution using **`os.urandom(12)`** was chosen. This strategy was adopted because the NIST standard for GCM strictly recommends this length to maximize performance and guarantee unpredictable entropy, completely preventing two encryptions from sharing the same initialization vector under the same key.

Metadata authentication strategy

A metadata authentication strategy using **AAD (Additional Authenticated Data)** was implemented by serializing a dictionary containing the version, original filename, and UTC timestamp, binding it directly to GCM's GHASH authentication tag calculation. This was chosen because protecting only the encrypted file is not enough against substitution attacks;

including metadata in authentication prevents an attacker from spoofing or reordering headers without the system invalidating decryption instantly.

Security Decisions

Why AEAD instead of encryption + hash?

It was decided to use a native primitive of **AEAD (AES-GCM) instead of combining traditional encryption with a summary function or HMAC** to eliminate human architectural errors. Manually combining these elements often leads to critical flaws in the order of operations or padding oracle vulnerabilities; in contrast, AEAD atomically couples confidentiality and integrity, guaranteeing safe and standard behavior.

What happens if nonce repeats?

The critical risk of the counter mode in GCM was evaluated, and **nonce reuse under the same key was categorically prohibited**, establishing fresh generation for each operation. This rule was prioritized because if a nonce repeats, system security collapses by allowing an attacker to calculate the keystream via XOR operations, exposing original data and completely destroying confidentiality.

What attacker are you defending against?

The system was designed to **defend against an active storage adversary** capable of intercepting, reading, copying, reordering, or maliciously modifying files and metadata in transit or at rest. To neutralize this attacker, an inflexible **fail-closed** policy was implemented via integrity exceptions **(`InvalidTag`)**, ensuring that upon the slightest anomaly, the system blocks immediately and refuses to output any fragment of information.